INCIDENT REPORT: PHISHING – UNFOLDING

PREPARED FOR: CISO

ANALYST: MMAKOLA THATO

DATE: 05/08/2026

TOOLING USED: ELK / KIBANA ONLY

1. 1. Executive Summary

During this shift, 36 SIEM alerts were triaged. The majority (~30) were confirmed false positives, consisting of benign phishing-style emails and clean process creation events. However, one alert involving a weaponized invoice attachment led to a confirmed compromise of user **Michael Escott's host**. The malicious file triggered a PowerShell-based attack chain (PowerView.ps1 execution, domain reconnaissance, attempted data exfiltration, and anti-forensic cleanup). The host was isolated, escalated for full incident response, and containment actions were recommended.

Verdict: True Positive – Critical. **Recommendation:** Immediate host isolation, password reset, forensic preservation, and blocking of malicious indicators.

2. 2. Incident Details

- **Date/Time of Alert: 08:05:2026 10:23:26GMT**
- **Alert Source:** SOC Simulator (ELK/Kibana)
- **Affected User/Asset:** Michael Escott, host win-3450
- **Classification:** Phishing email with weaponized attachment → PowerShell-based compromise

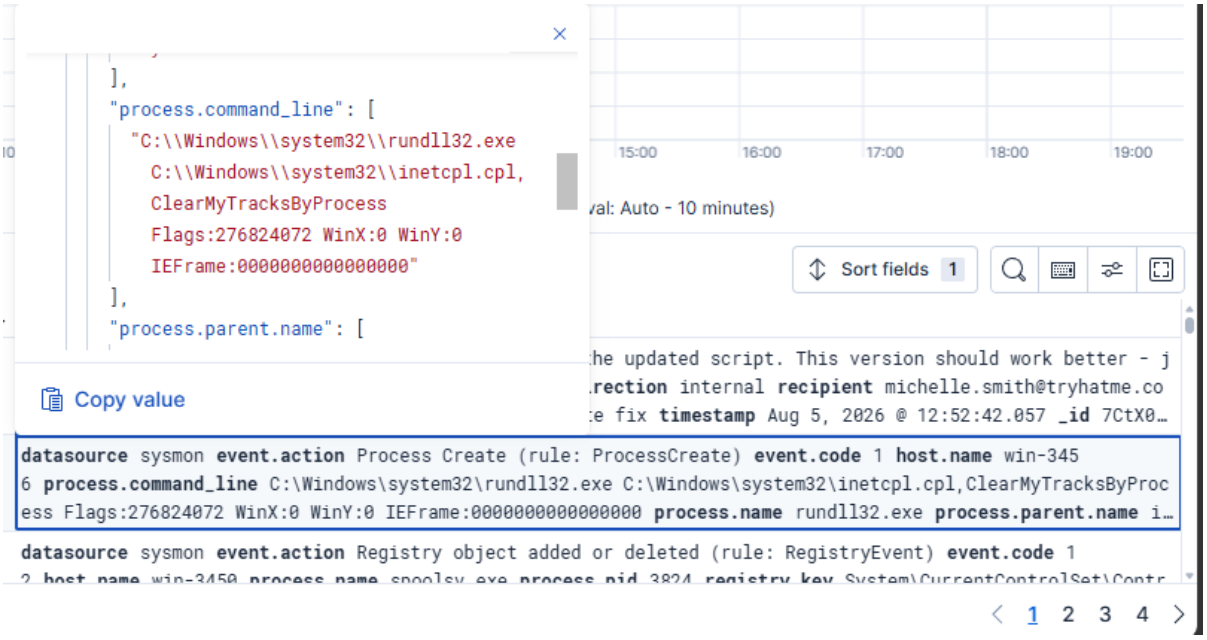
3. 3. Investigation Timeline

1. **Initial triage:** Reviewed multiple phishing-style emails (Alerts 1–5, 9–12) — no attachments or links, closed as false positives.
2. **Alert 6:** Identified phishing email with a suspicious `.zip` attachment disguised as a PDF invoice. Pivoted on attachment filename and sender domain in Kibana . See screenshot below



- malicious file attached that has deception note text that indicates the attacker attempted to disguise this .zip file as pdf which is risky because attacker used compressed .zip file to hide malicious executable programs or scripts from basic email scanner

3. **Execution observed:** Shortly after, PowerShell script **PowerView.ps1** executed from Downloads folder (Alert 13).
4. **Reconnaissance:** NSLookup activity flagged (Alert 14), consistent with domain/network mapping.
5. **Exfiltration attempts:** Robocopy and NSLookup commands detected (Alert 15).
6. **Cleanup:** File deletion activity (Alert 16) indicated anti-forensic behavior. See screenshot bellow



this log indicates that a windows process triggered a cleanup function to clear internet data or cache , is normal if it was done by user if is not the user that would scream phishing and deletion of lateral movement inside a compromised device

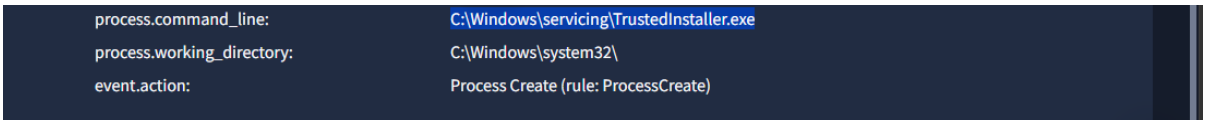
7. **Escalation:** Host isolated, incident escalated to Tier 2/IR team for further investigation.

4. 4. Evidence & Analysis

- **Email inspection (Alert 6):** Subject line “Important Invoice for February” contained urgency language. Kibana logs showed `.zip` attachment with disguised executable.

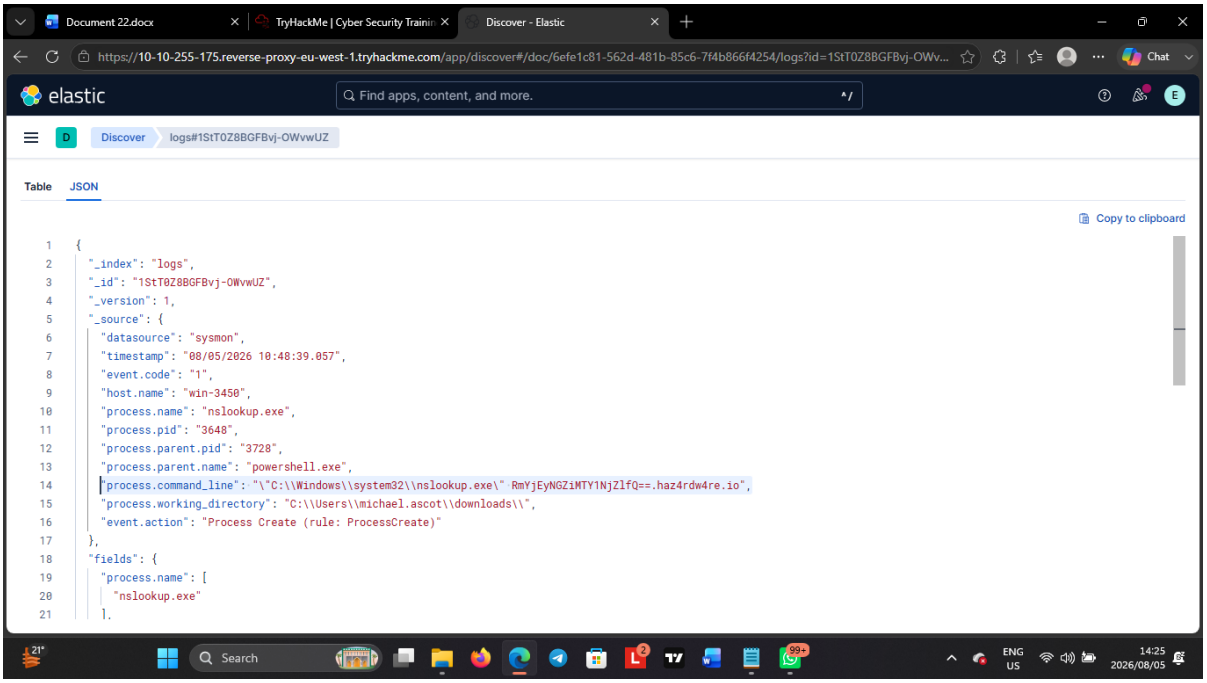


- **Process creation:** Kibana process logs confirmed execution of PowerView.ps1 in Downloads folder



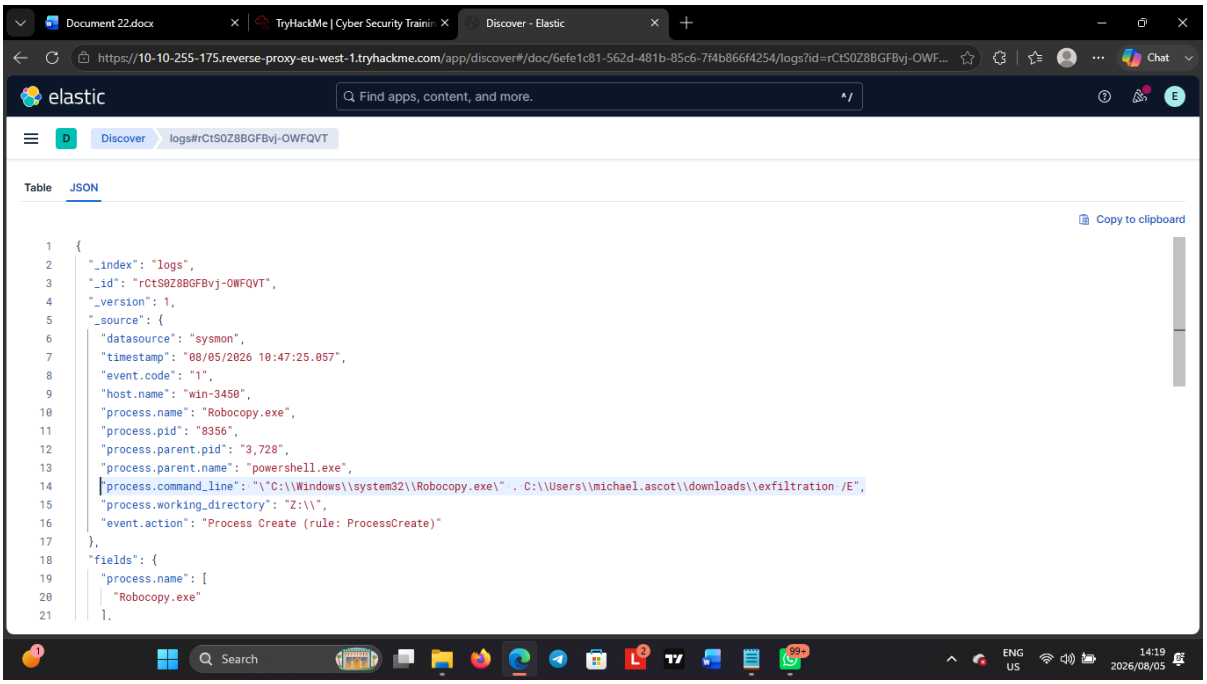
.

- **Reconnaissance:** NSLookup queries pivoted in Kibana revealed enumeration of network shares



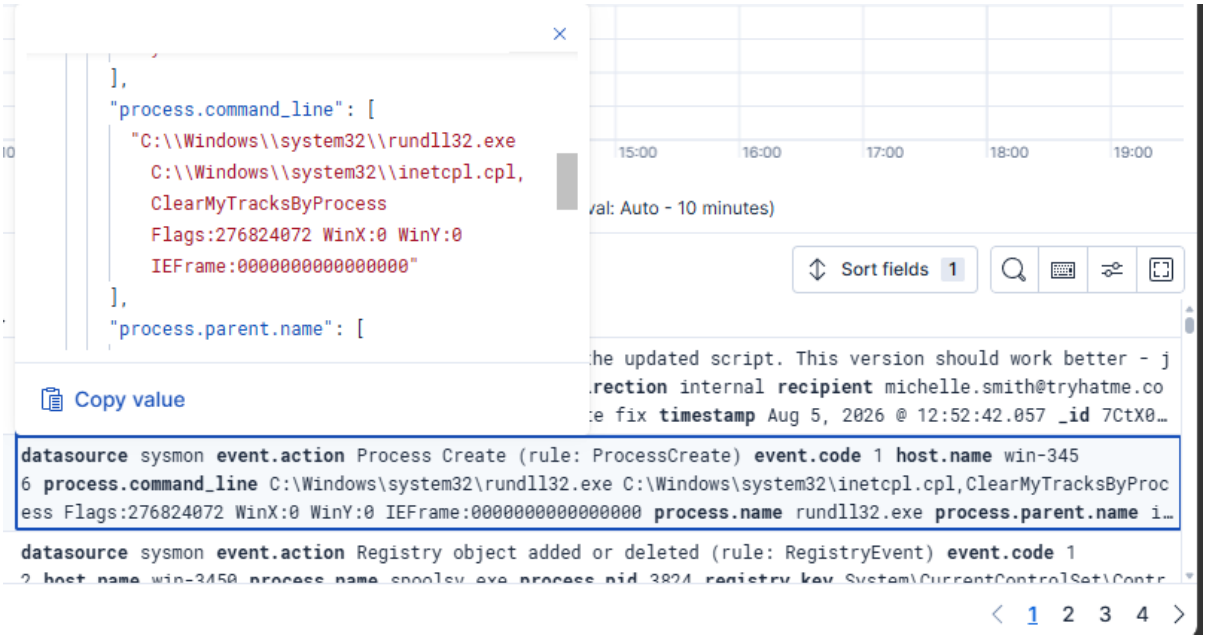
this command performing DNS-based data exfiltration , this technigue is used by attackers to secretly steal files out of a network.

- **Exfiltration:** Robocopy commands in Kibana logs showed attempted staging of files



.

- **Anti-forensics:** PowerShell deletion commands observed in Kibana, targeting Downloads folder.



igure 1 – Kibana email alert view, Figure 2 – process creation logs, Figure 3 – NSLookup query logs, Figure 4 – Robocopy command evidence, Figure 5 – deletion command evidence)

5. 5. Indicators of Compromise (IOCs)

- **Sender Domain:** john@hatmakerurope.xyz **-bad guys use this .xyz to baypass spam filter**
- **Attachment Filename:** importantnotice-february.zip disguised as PDF]
- **File Hash:** NONE

- **Script:** PowerView.ps1
- **Host:** win-3450
- **User:** Michael Escott

6. 6. Verdict & Severity

- **Verdict:** True Positive – Critical
- **Justification:** Clear evidence of phishing delivery, malicious attachment execution, domain reconnaissance, exfiltration attempts, and anti-forensic cleanup.
- **Severity:** Critical — compromise of internal host with attempted data theft.

7. 7. Recommendations & Remediation

- Isolate hostwin-3450 immediately.
- Force password rotation for Michael Escott.
- Quarantine and remove malicious files from Downloads folder.
- Block sender domain and malicious file hash at email gateway.
- Review mail logs for other recipients of the same phishing email.
- Preserve forensic artifacts before remediation.
- Notify data owners of potentially targeted financial records.

8. 8. Lessons Learned

- A single phishing click escalated into a full attack chain — reinforces need for **sandboxing attachments** at the email gateway.
- Manual inspection of file extensions is critical — attackers used typo-squatting to disguise executables.
- Grouping identical false positives saved time and avoided redundant triage.
- Tracking related alerts as one continuous incident improved escalation efficiency.